

Ritual Consumer MFA Implementation

Ritual Consumer MFA Implementation

Version: 1.0

Effective Date: 2026-03-18

Owner: Nicholas Gardner, Founder, Ritual

Overview

Ritual uses Clerk for consumer authentication on its web and mobile applications.

For higher-sensitivity financial connectivity features, Ritual requires that the consumer account have multi-factor authentication enabled before the Plaid Link flow can be surfaced from the product.

MFA Strategy

Ritual's current consumer MFA implementation is based on Clerk's supported MFA methods:

- authenticator application (TOTP)
- SMS verification code
- backup codes

Ritual's recommended production configuration is:

- enable Authenticator application
- enable Backup codes
- optionally enable SMS verification code if desired
- enable Require multi-factor authentication in Clerk

Product Enforcement

Ritual's product-side controls for Plaid are:

- Ritual uses Clerk-authenticated sessions for access to the application
- the Plaid integration checks whether the authenticated user has MFA enabled
- if MFA is not enabled, Ritual does not surface the bank connection flow and instead directs the user to account security settings to complete MFA setup first

This creates an explicit control that prevents users without MFA-enabled accounts from initiating the Plaid connection flow from within Ritual.

User Experience

If a user has not enabled MFA:

- the Plaid / Spending integration card shows an MFA requirement state
- the Plaid details panel indicates that MFA must be enabled before bank connections are available
- the user is directed to Clerk account security settings to configure MFA

If a user has MFA enabled:

- the user can proceed to the Plaid connection flow normally

Current Implementation References

- `apps/dashboard/app/(dashboard)/integrations/integrations-client.tsx`
- `apps/dashboard/components/settings-modal.tsx`
- `apps/backend/services/auth_service.py`
- `apps/backend/api/financial.py`

Important Note for Vendor Questionnaires

Ritual can currently support an honest response of:

`Yes – Non-phishing-resistant multi-factor authentication is performed`

based on Clerk's currently supported MFA methods such as TOTP and SMS.

Ritual should not represent this control as phishing-resistant MFA unless the authentication flow is changed to a qualifying phishing-resistant control and that control is enforced before Plaid Link is surfaced.